

DevSecOps END 2 End : Sonarqube + OWASP + trivy + Docker+ Jenkins + **Docker Compose**

3 tier app deployment (trainwithshubham) good project understand mongo db ,redis, frontend backend

Name: devops-learning

O.S = ubuntu

Instance type T2.large : Because you have to install all tools.

SSH,HTTPS,HTTPS

Storage : 10 - 15 GB

No. of instance = 1

Now **connect** :

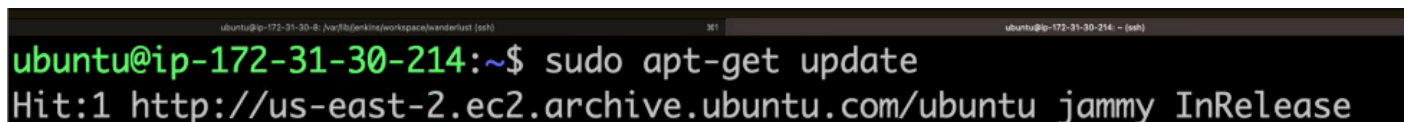
Ssh -l "<keyname>' ubuntu@<IPserver>

You can go to aws dashboard select instance

Wonderlust : devops branch (git)

Install sonarqube through docker

1. **System Update** :

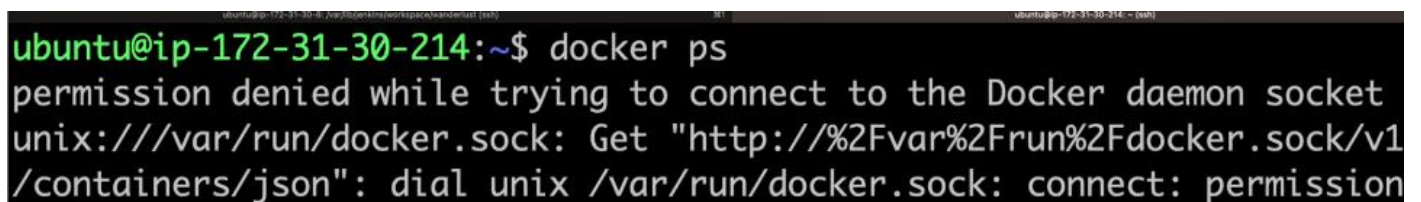


```
ubuntu@ip-172-31-30-214:~$ sudo apt-get update
Hit:1 http://us-east-2.ec2.archive.ubuntu.com/ubuntu jammy InRelease
```

- Docker and docker-compose installed



```
sudo apt-get update
sudo apt-get install docker.io -y
sudo apt-get install docker-compose -y
```



```
ubuntu@ip-172-31-30-214:~$ docker ps
permission denied while trying to connect to the Docker daemon socket
unix:///var/run/docker.sock: Get "http://%2Fvar%2Frun%2Fdocker.sock/v1/containers/json": dial unix /var/run/docker.sock: connect: permission
```

Our user need **Docker permission**.

```
ubuntu@ip-172-31-30-214:~$ whoami
ubuntu
ubuntu@ip-172-31-30-214:~$
```

Add user & Reboot

```
ubuntu@ip-172-31-30-214:~$ sudo usermod -aG docker $USER
ubuntu@ip-172-31-30-214:~$ sudo reboot
Connection to ec2-3-19-228-164.us-east-2.compute.amazonaws.com
remote host.
```

Again SSH

```
ubuntu@ip-172-31-30-214:~$ docker ps
CONTAINER ID   IMAGE     COMMAND   CREATED   STATUS    PORTS
ubuntu@ip-172-31-30-214:~$
```

Install JAVA: (official document)

```
ubuntu@ip-172-31-30-214:~$ sudo apt update
sudo apt install fontconfig openjdk-17-jre
```

Install Jenkins :

Long term support release.

Long Term Support release

A [LTS \(Long-Term Support\) release](#) is chosen every 12 weeks from the stream of regular releases. It can be installed from the [debian-stable apt repository](#).

```
sudo wget -O /usr/share/keyrings/jenkins-keyring.asc \
https://pkg.jenkins.io/debian-stable/jenkins.io-2023.key
echo "deb [signed-by=/usr/share/keyrings/jenkins-keyring.asc] \
https://pkg.jenkins.io/debian-stable binary/" | sudo tee \
/etc/apt/sources.list.d/jenkins.list > /dev/null
sudo apt-get update
sudo apt-get install jenkins
```

Status Jenkins :

```
ubuntu@ip-172-31-30-214:~$ systemctl status jenkins
```

And jenkins run on port **8080**, Now I go to instance **security group inbound rule 8080** anywhere
copy pub ip : browser <pub IP>:8080

Unlock Jenkins :

```
ubuntu@ip-172-31-30-214:~$ sudo cat /var/lib/jenkins/secrets/initialAdminPassword
4be24d97a86d4f0f96e249de751896a1
```



Create First Admin User

Username
admin

Password

Confirm password

Full name
admin

E-mail address
trainwithshubham@gmail.com

Admin admin **admin** admin : email for email alert

Required Plugin : Available

2. Plugins Installation:

- Go to **Manage Jenkins**, click on **Plugins** and install all the plugins listed below, we will require for other tools integration:
 - SonarQube Scanner (Version2.16.1)
 - Sonar Quality Gates (Version1.3.1)
 - OWASP Dependency-Check (Version5.4.3)
 - Docker** (Version1.5)

Install + Restart

Again sign in : admin , admin

Setup sonarqube through Docker :

Port : 9000

```
ubuntu@ip-172-31-30-214:~$ docker run -itd --name sonarqube-server -p 9000:9000 sonarqube:lts-community
```

```
ubuntu@ip-172-31-30-214:~$ docker ps
CONTAINER ID   IMAGE                                COMMAND
STATUS        PORTS
920ca6351754   sonarqube:lts-community            "/opt/sonarqube/do
nds ago       Up 5 seconds    0.0.0.0:9000->9000/tcp, :::9000->9000/tcp
rube-server
```

Security Group : inblund rule 9000 : anywhere ipv4

Browser : <IPv4>:9000

Login : Admin + admin

We want **send report** to from Jenkins --- > sonarqube --- > Return to jenkins

URL + URL = webhook we called it . **Sonarqube** we generate **Tokken**

Setup Trivy :

```
ubuntu@ip-172-31-30-214:~$ sudo apt-get install wget apt-transport-https gnupg lsb-release
```

```
ubuntu@ip-172-31-30-214:~$ wget -qO - https://aquasecurity.
y-repo/deb/public.key | gpg --dearmor | sudo tee /usr/share
y.gpg > /dev/null
```

```
ubuntu@ip-172-31-30-214:~$ echo "deb [signed-by=/usr/share/k
.gpg] https://aquasecurity.github.io/trivy-repo/deb $(lsb_re
in" | sudo tee -a /etc/apt/sources.list.d/trivy.list
```

```
ubuntu@ip-172-31-30-214:~$ sudo apt-get update
```

```
sudo apt-get update
```

```
sudo apt-get install trivy
```

Lets say you want to scan Image ;

▼ Trivy Commands

```
trivy image imagename
```

```
trivy fs --security-checks vuln,config Folder_name_OR_Path
```

```
trivy image --severity HIGH,CRITICAL image_name
```

```
trivy image -f json -o results.json image_name
```

```
trivy repo repo-url
```

```
trivy k8s --report summary cluster
```

Example : lets say **Redis** image

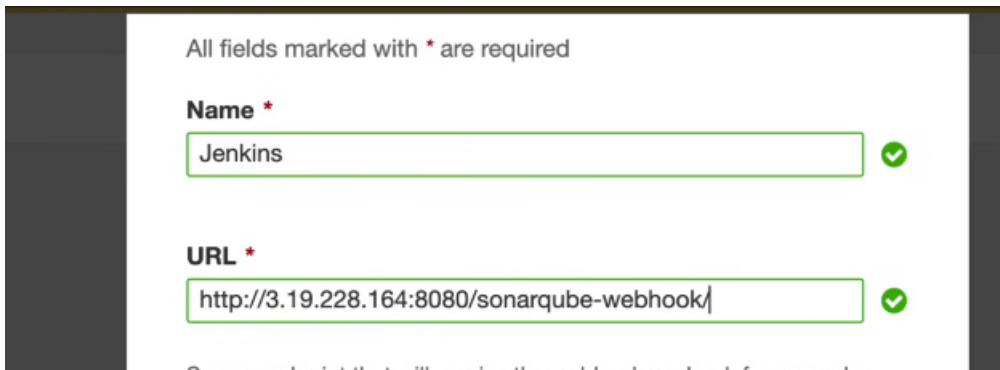
```
ubuntu@ip-172-31-30-214:~$ trivy image redis
```

After that what happen trivy redis image downlaod it and scan it and it will check is there any kind pf vulnerability

CVE :

Jenkins + Sonarqube Integration :

Go to Sonarqube : Administration + Configuration + webhooks + create +name (jenkins)+ URL (jenkins)



All fields marked with * are required

Name *

Jenkins ✓

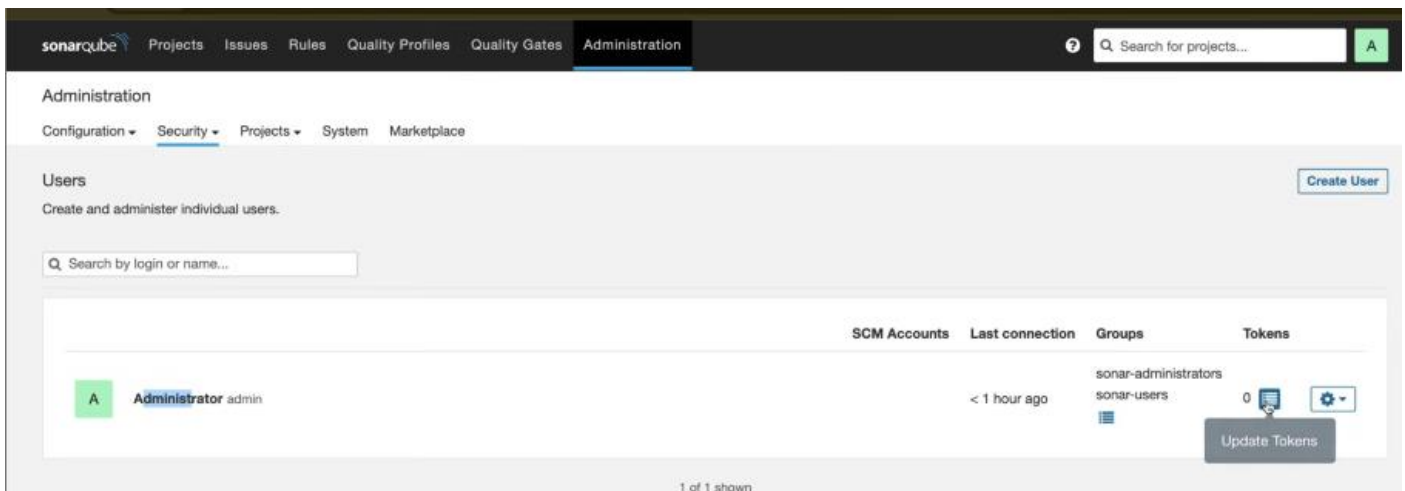
URL *

http://3.19.228.164:8080/sonarqube-webhook/ ✓

Create : No need to fill secret

Generate Token : why we want jenkins --> sonarqube

Sonarqube : Security + user + token



sonarqube Projects Issues Rules Quality Profiles Quality Gates Administration

Administration

Configuration Security Projects System Marketplace

Users

Create and administer individual users.

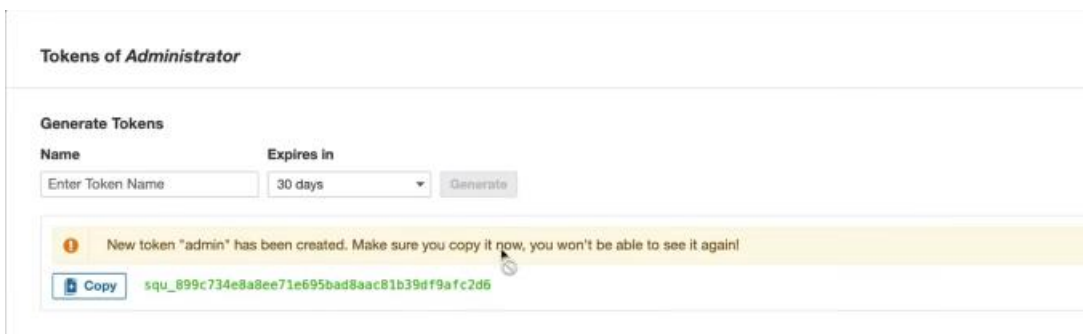
Create User

Search by login or name...

	SCM Accounts	Last connection	Groups	Tokens
 Administrator admin		< 1 hour ago	sonar-administrators sonar-users	0  

Update Tokens

1 of 1 shown



Tokens of Administrator

Generate Tokens

Name Expires in

Enter Token Name 30 days Generate

New token "admin" has been created. Make sure you copy it now, you won't be able to see it again!

Copy squ_699c734e8a8ee71e695bad8aac81b39df9afc2d6

Manage jenkins + security + credentials

Kind

Secret text

Scope ?

Global (Jenkins, nodes, items, all child items, etc)

Scope ?

Global (Jenkins, nodes, items, all child items, etc)

Secret

.....

ID ?

Sonar

Description ?

Sonar

Create

Now go to jenkins + Manage jenkins + system + global + add credentials

SonarQube servers

If checked, job administrators will be able to inject a SonarQube server configuration as environment variables in the build.

☐ Environment variables

SonarQube installations

List of SonarQube installations

Name

Sonar

Server URL

Default is http://localhost:9000

http://3.19.228.164:9000

Server authentication token

SonarQube authentication token. Mandatory when anonymous access is disabled.

- none -

+ Add

Save !

SonarQube Scanner installations

Add SonarQube Scanner

☰ SonarQube Scanner

Name

Name

Sonar

! Required

☒ Install automatically ?

☰ Install from Maven Central

Version

SonarQube Scanner 5.0.1.3006

SAVE:

OWASP setup :

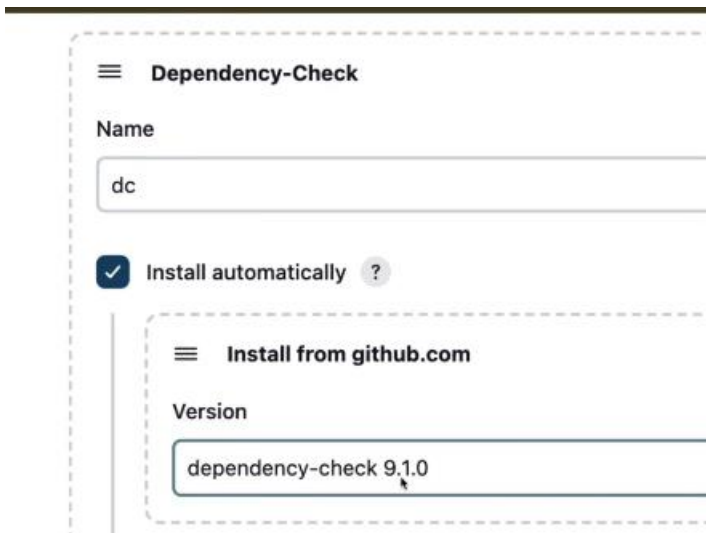
Manage Jenkins + Tool +

Dependency-Check installations

Add Dependency-Check

☰ Dependency-Check

Installation directory don't select any thing



Dependency-Check

Name

dc

☒ Install automatically ?

Install from github.com

Version

dependency-check 9.1.0

Save :

Now Jenkins tell OWASP that I have these dependencies and OWASP check it and give report to Jenkins that OK or not

```
ubuntu@ip-172-31-30-214:~$ trivy --version
Version: 0.50.1
Vulnerability DB:
  Version: 2
  UpdatedAt: 2024-04-21 00:15:44.479708709 +0000 UTC
  NextUpdate: 2024-04-21 06:15:44.479708309 +0000 UTC
  DownloadedAt: 2024-04-21 06:06:33.369051585 +0000 UTC
ubuntu@ip-172-31-30-214:~$
```

Now **Create Pipeline** :

1. If you want to use Jenkins file then select : Pipeline script from SCM (git hub)
2. Pipeline script

New item + pipeline (wanderlust-ci-cd)

Configure

General



General



Advanced Project Options



Pipeline

Description

This is a CI/CD DevSecOps for Wanderlust project

General



Advanced Project Options



Pipeline

Description

This is a CI/CD DevSecOps for Wanderlust project

Plain text [Preview](#)

☐ Discard old builds [?](#)

☐ Do not allow concurrent builds

☐ Do not allow the pipeline to resume if the controller restarts

☒ GitHub project

Project url [?](#)

<https://github.com/krishnaacharyaa/wanderlust>

Advanced [v](#)

☐ Pipeline speed/durability override [?](#)

☒ Throttle builds [?](#)

Number of builds [?](#)

1

Approximately 60 minutes between builds

Build Triggers

☐ Build after other projects are built [?](#)

☐ Build periodically [?](#)

☒ GitHub hook trigger for GITScm polling [?](#)

☐ Poll SCM [?](#)

Advanced Project Options

Advanced [^](#)

[/](#) Edited

Display Name [?](#)

Wanderlust CICD

```

1 pipeline{
2     agent any
3     environment{
4         SONAR_HOME= tool "Sonar"
5     }

```

```

3     environment{
4         SONAR_HOME= tool "Sonar"
5     }
6     stages{
7         stage("Clone Code from GitHub"){
8             steps{
9                 git url: "https://github.com/krishnaacharyaa/wanderlust.git", branch: "devops"
10            }
11        }

```

When you want to sonarqube analysis you need Environment variable

withSonarQubeEnv(name of variable)

```

stage("SonarQube Quality Analysis"){
    steps{
        withSonarQubeEnv("Sonar"){
            sh "$SONAR_HOME/bin/sonar-scanner -Dsonar.projectName=wanderlust -Dsonar.projectKey=wanderlust"
        }
    }
}

```

SAVE + Now I check only these stage working or not.

Build Now

Now where you can see **Quality Analysis Console Output**

The image shows two parts of the process. The top part is a screenshot of the Jenkins console output for a build. It shows two stages, #1 and #2, both marked with green checkmarks. Stage #1 is expanded, showing the command executed: `sh "$SONAR_HOME/bin/sonar-scanner -Dsonar.projectName=wanderlust -Dsonar.projectKey=wanderlust"`. The bottom part is a screenshot of the SonarQube dashboard for the project 'wanderlust'. The 'QUALITY GATE STATUS' is prominently displayed as 'Passed' in a green box, with the text 'All conditions passed.' below it. The dashboard also shows 'MEASURES' for 'New Code' and 'Overall Code'.

There is a catch **OWASP** dep tak time to **download dependency** .

./ Scan all directory

odcInstallation: dc

publisher report you have to store report in **html or xml**

--scan ./ all directories , durig tool setup you put name = dc, ** means current directory

```
stage("OWASP Dependency Check"){
  steps{
    dependencyCheck additionalArguments: '--scan ./', odcInstallation: 'dc'
    dependencyCheckPublisher pattern: '**/dependency-check-report.xml'
  }
}
```

Wait 2 min

[Let say I Mention like quality gate my code pass 70% than it will go to next step other wise failed]

[abort pipeline = false it will contineu WaitForQuality gate is command which start quality gate]

```
stage("Sonar Quality Gate Scan"){
  steps{
    timeout(time: 2, unit: "MINUTES"){
      waitForQualityGate abortPipeline: false
    }
  }
}
```

```
25 stage("Trivy File System Scan"){
26   steps{
27     sh "trivy fs --format table -o trivy-fs-report.html ."
28   }
29 }
30 }
```

Now again we build now

Some time what happen devloper write **backend** -- > **test** these you have to **integrate in your code**

You can add test in your docker file also, You have to go to backend dockerfile .

How I know package.json ther I see test name directory so basically when ever my docker build it will run that test. So if you want run test than go to frontend and backend docker file add test command because we can see there also available.

```
{
  "name": "frontend",
  "private": true,
  "version": "0.0.0",
  "type": "module",
  "scripts": {
    "dev": "vite",
    "build": "tsc -p tsconfig.prod.json && vite",
    "lint": "eslint . --ext ts,tsx --report-un",
    "preview": "vite preview",
    "format": "prettier --write .",
    "test": "jest"
  }
}
```

```
},
"scripts": {
  "test": "jest --watchAll --detectOpenHandles --verbose --coverage ",
  "start": "nodemon server.js",
  "check": "prettier --check .",
  "format": "prettier --write .",
}
```

```
# packages install
RUN npm i

# tests
RUN npm run test
```

Report Publish in `/var/lib/jenkins/workspace/wonderlust-ci-cd/dependency-report.xml`

```
ubuntu@ip-172-31-5-30:~$ cd /var/lib/jenkins/workspace/wanderlust-ci-cd/
ubuntu@ip-172-31-5-30:/var/lib/jenkins/workspace/wanderlust-ci-cd$ ls
LICENSE      dependency-check-report.xml  package-lock.json
README.md    docker-compose.yml         package.json
backend      frontend
ubuntu@ip-172-31-5-30:/var/lib/jenkins/workspace/wanderlust-ci-cd$
```

You show to your developer .

Deploy application :

-d background

```
37 - stage("Deploy using Docker compose"){
38 -   steps{
39     sh "docker-compose up -d"
40   }
41 }
42 }
```

Build Now :

We see **Error** jenkins user **permission denied** : we want to add Jenkins to docker group.

Another option if you don't want to **reboot system**

```
ubuntu@ip-172-31-5-30:~$ whoami
ubuntu
ubuntu@ip-172-31-5-30:~$ sudo usermod -aG docker jenkins
ubuntu@ip-172-31-5-30:~$ sudo systemctl restart docker
ubuntu@ip-172-31-5-30:~$ sudo systemctl restart jenkins
```

You know that docker is run on **Sonarqube** but we **restart** it it means it is **exist**

```
ubuntu@ip-172-31-5-30:~$ docker ps -a
CONTAINER ID   IMAGE                                COMMAND                  CREATED
STATUS        PORTS          NAMES
8a59b613fc0a   sonarqube:lts-community             "/opt/sonarqube/dock... 43 min
tes ago      Exited (130) 24 seconds ago          sonarqube-server
```

```
ubuntu@ip-172-31-5-30:~$ docker start 8a59b613fc0a
8a59b613fc0a
ubuntu@ip-172-31-5-30:~$
```

Security Group : **5173** (application deployment) , **5000** port enable .

Browser : serverIP:5173 - - > Website

trainwithshubham.com

Overview **DNS** Products

DNS Records Forwarding Nameservers Premium DNS Hostnames DNSSEC **NEW** Crypto Wallet

DNS records define how your domain behaves, like showing your website content and delivering your email.

New Records

A records use an IP address to connect your domain to a website. They're also used to [create subdomains](#) such as www or store, that point to an IP address.

Type *	Name *	Value *	TTL
A	wanderlust	3.133.123.203	Custom
			Seconds
			600

[Add another value](#)

Add More Records **Save** Cancel

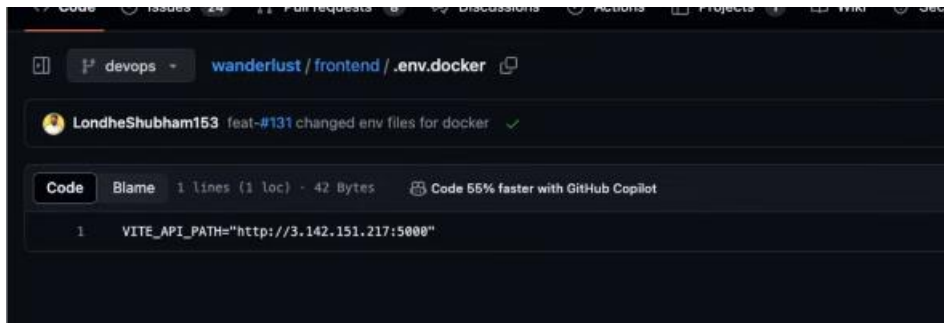
Basically:

Google : wonderlust.tarinwithshubham.com:5173 we see website

Basically docmain map

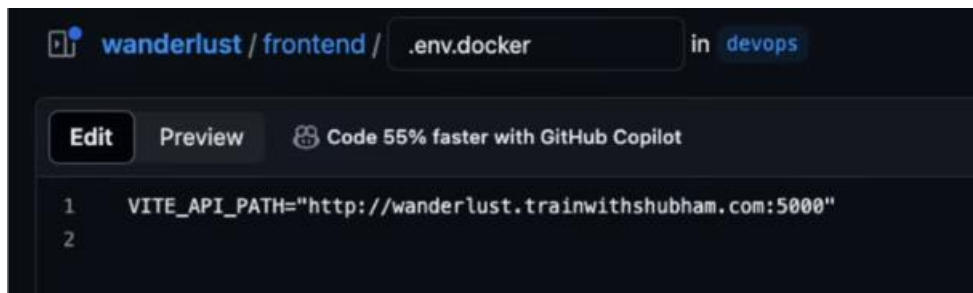
Updating DNS (Godaddy) Change IP **Hard coded**

I can do one more thing wonderlust.tarinwithshubham.com:5173 I put it into my environment variable



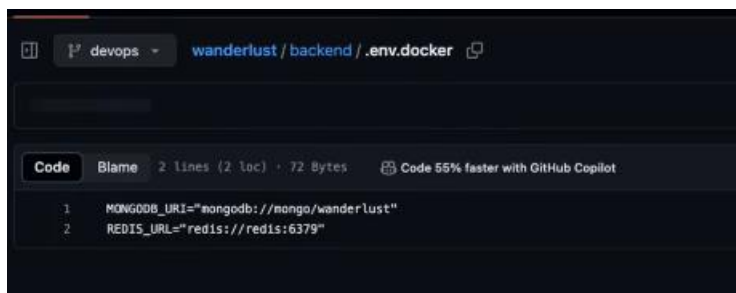
A screenshot of a GitHub repository showing the file `wanderlust / frontend / .env.docker`. The file content is a single line: `VITE_API_PATH="http://3.142.151.217:5000"`. The interface includes a commit message "LondheShubham153 feat-#131 changed env files for docker" and a "Code" button.

Or



A screenshot of a GitHub repository showing the file `wanderlust / frontend / .env.docker` in the `devops` branch. The file content is a single line: `VITE_API_PATH="http://wanderlust.trainwithshubham.com:5000"`. The interface includes buttons for "Edit" and "Preview", and a "Code" button.

Backend : no need to change .



A screenshot of a GitHub repository showing the file `wanderlust / backend / .env.docker`. The file content is two lines: `MONGODB_URI="mongodb://mongo/wanderlust"` and `REDIS_URL="redis://redis:6379"`. The interface includes buttons for "Code" and "Blame".

In future ip change we just update godaddy .

Another wasy it using Nginx .

